Cybersecurity Daily Newsletter

Vol. 007 | 2026-11-06 09:00 WIB

Top 5 Highlights

• ISC Stormcast For Friday, November 6th, 2026 https://isc.sans.edu/podcastdetail/10168, (Fri, Nov 6th)

• OpenSSH flaw lets attackers access password-disabled accounts on some Linux systems

• New CWPdoor malware targets Linux servers via Control Web Panel

• DigiCert reports data breach following server migration error

• Android devices vulnerable to ghostmap boot loop attack

Threat Intelligence (10)

01. ISC Stormcast For Friday, November 6th, 2026 https://isc.sans.edu/podcastdetail/10168, (Fri, Nov 6th)

ISC Stormcast For Friday, November 6th, 2026 https://isc.sans.edu/podcastdetail/10168, (Fri, Nov 6th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://isc.sans.edu/diary/rss/33494

02. New CWPdoor malware targets Linux servers via Control Web Panel

CWPdoor is a stealthy Linux malware strain currently targeting the Control Web Panel management interface by replacing the legitimate cwpsrv binary with a malicious version, as first reported by Bleeping Computer.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.scworld.com/brief/new-cwpdoor-malware-targets-linux-servers-via-control-web-panel

03. Binance heist is stark example of AI governance gaps and basic security failures

A chain of avoidable technical and human security failures enabled the largest crypto heist on record, the theft of approximately $6.34 billion from Binance…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.csoonline.com/article/4245354/binance-heist-is-stark-example-of-ai-governance-gaps-and-basic-security-failures.html

04. Fake OpenAI, SpaceX events used to steal Microsoft, Google accounts

Hackers are using fake OpenAI, SpaceX, and Anthropic event invitations to lure employees into phishing attacks, using two different phishing-as-a-service platforms to steal Microsoft and Google account credentials and authentication sessions. […]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.bleepingcomputer.com/news/security/fake-openai-spacex-events-used-to-steal-microsoft-google-accounts/

05. What We Missed: Knicks Phishing Test Goes Out of Bounds

In this video conversation, Dark Reading editors discuss some of the news they didn't get a chance to cover, from an ill-conceived phishing simulation to a hacktivist attack on a US government agency.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.darkreading.com/cyber-risk/what-we-missed-knicks-phishing-test-out-of-bounds

06. APT29's Watering Holes Target Thousands of Mobile Users

After compromising websites, the Russian state-sponsored threat group is fingerprinting victims, then harvesting information from the interesting ones.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/mobile-security/apt29-watering-holes-target-mobile-users

07. Hackers backdoor Linux servers using trojanized CWP web server

A new Linux malware called CWPdoor is being distributed through a trojanized version of cwpsrv, the web server behind the Control Web Panel (CWP) management interface. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/hackers-backdoor-linux-servers-using-trojanized-cwp-web-server/

08. Email threat landscape: Q3 2026 trends and insights

Microsoft Threat Intelligence observed a sharp rise in email-based phishing activity at the end of Q3 2026 (July - September), even as QR code phishing declined, CAPTCHA-gated phishing recovered, and malicious messages spoofing familiar business-service sender domains exposed risks associated with security overrides. The post Email threat landscape: Q3 2026…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.microsoft.com/en-us/security/blog/2026/11/05/email-threat-landscape-q3-2026-trends-and-insights/

09. Vercel ties login sessions to devices, rolls out AI security reviews in public beta

Vercel, the popular cloud platform for building and hosting websites and web applications, has announced the rollout of Device Bound Session Credentials (DBSC) and the launch of Vercel Security Review in public beta. Making stolen session cookies worthless Device Bound Session Credentials is a security technology designed to limit the consequences of an inf…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.helpnetsecurity.com/2026/11/05/vercel-security-review-session-hijacking/

10. ChatGPT Lockdown Mode Bypass: Phishing, Malware Delivery, and Silent Data Exfiltration

Research by: Alexey Bukhteyev Key Takeaways Introduction Earlier this year, Check Point Research disclosed a security flaw in ChatGPT’s code-execution runtime that allowed sensitive conversation data to be silently exfiltrated to an attacker-controlled server through DNS tunneling, a hidden outbound channel that bypassed the runtime’s network isolation. A f…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://research.checkpoint.com/2026/chatgpt-lockdown-mode-bypass-phishing-malware-delivery-and-silent-data-exfiltration/

Latest Vulnerabilities (10)

01. OpenSSH flaw lets attackers access password-disabled accounts on some Linux systems

A critical vulnerability that affects OpenSSH servers on Linux systems built with the musl C library instead of glibc allows remote attackers to easily bypass authentication and log into accounts that should have password authentication disabled. The flaw impacts the lightweight Alpine Linux, which is widely used for cloud Docker container images, as well a…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4245407/openssh-flaw-lets-attackers-access-password-disabled-accounts-on-some-linux-systems.html

02. Android devices vulnerable to ghostmap boot loop attack

Android devices are susceptible to a denial-of-service vulnerability known as GhostMap that can force smartphones into a continuous boot loop.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/android-devices-vulnerable-to-ghostmap-boot-loop-attack

03. Security vulnerability discovered in OpenSSH on musl-based Linux systems

As outlined in The Register, a security vulnerability dubbed *sshole allows attackers to gain root access on certain Linux systems by entering a password longer than 256 bytes.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/security-vulnerability-discovered-in-openssh-on-musl-based-linux-systems

04. Introducing AWS account access manager: IAM role flexibility with centralized workforce access

AWS Identity and Access Management (IAM) is introducing account access manager, a flexible new way to manage workforce access to your Amazon Web Services (AWS) accounts. This combines the IAM role flexibility your teams already rely on, delivered through the centralized federation of AWS IAM Identity Center, with user-level visibility built-in. Account acce…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://aws.amazon.com/blogs/security/introducing-aws-account-access-manager-iam-role-flexibility-with-centralized-workforce-access/

05. Get root on a musl Linux system by slamming it with an overly long password

Decade-old vulnerability in OpenSSH is now fixed, so get a-patchin'

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/11/05/get-root-on-a-musl-linux-system-by-slamming-it-with-an-overly-long-password/5307910

06. October crypto-tracker hack: Access cracked, law enforcement tokens packed

Agentic 'on-path attack' went after Chainalysis's tools, which are routinely called upon to assist police investigations

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/cyber-crime/2026/11/05/october-crypto-tracker-hack-access-cracked-law-enforcement-tokens-packed/5307852

07. OpenAI built an AI pipeline to find, exploit and patch Linux flaws

OpenAI has developed an autonomous AI pipeline that can identify software vulnerabilities, develop working exploits to validate their impact and generate patches for human review. In an October experiment targeting the Linux kernel, the pipeline created exploits for 948 distinct local privilege-escalation (LPE) vulnerabilities at a total API cost of $1.2 mi…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4245265/openai-built-an-ai-pipeline-to-find-exploit-and-patch-linux-flaws.html

08. OpenSSH flaw lets attackers log into password-disabled Linux accounts

A newly disclosed OpenSSH vulnerability dubbed "*sshole" allows attackers to log in to certain Alpine Linux and other musl-based Linux accounts that are configured to block password authentication, simply by entering an oversized password. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/openssh-flaw-lets-attackers-log-into-password-disabled-linux-accounts/

09. AI Agents Got Root on Linux via 948 Kernel Flaws in OpenAI Research

An unreleased OpenAI cyber model found and exploited 948 distinct Linux kernel privilege escalation bugs for about $1.2 million. The post AI Agents Got Root on Linux via 948 Kernel Flaws in OpenAI Research appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.securityweek.com/ai-agents-got-root-on-linux-via-948-kernel-flaws-in-openai-research/

10. Hacking on Autopilot: Inside ARTEX Cybercrime Campaigns

Key Points Introduction ARTEX is a Chinese open-source, AI-powered penetration testing platform designed to help security teams assess systems they own or are authorized to test. It uses large language models (LLMs) to coordinate multiple AI agents that plan tests, run security tools, and record evidence of potential vulnerabilities. Its web dashboard bring…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://research.checkpoint.com/2026/hacking-on-autopilot-inside-artex-cybercrime-campaigns/

Data Breach & Cybercrime (10)

01. DigiCert reports data breach following server migration error

DigiCert suffered a data breach after a server migration mistakenly exposed an internal business system to the internet, allowing unauthorized access to customer information and identity documents, according to a recent report by Bleeping Computer.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/digicert-reports-data-breach-following-server-migration-error

02. Bristol schools data breach leads to online leak of 320,000 files

As detailed in Tech Radar, a significant cyberattack targeting the Bristol school network has resulted in the unauthorized release of over 320,000 stolen files on the dark web.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/bristol-schools-data-breach-leads-to-online-leak-of-320000-files

03. French banking group hit by supply chain cyberattack

French regional banking group Crédit Mutuel Arkéa admitted Wednesday that attackers had accessed an internal account via an unnamed third-party service provider’s platform and transferred funds to other financial institutions. Those funds, it said, could have then been potentially converted to cryptocurrency by the thieves. The day before, cryptocurrency ne…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.csoonline.com/article/4245357/french-banking-group-hit-by-supply-chain-cyberattack.html

04. Phone return scams: where a real delivery and a fake return end up in a bill for you

Phone return scams are part of a very convincing social engineering method where the criminals gets a phone and you get billed.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/threat-intel/2026/11/phone-return-scams-where-a-real-delivery-and-a-fake-return-end-up-in-a-bill-for-you

05. Scammers use AI-generated images of missing pets to extort owners

Scammers are using AI images to enhance their "I've found your missing pet and want money to return it to you" schemes.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/ai/2026/11/scammers-use-ai-generated-images-of-missing-pets-to-extort-owners

06. DigiCert data breach exposes customer information, identity documents

DigiCert warns it suffered a data breach after a server migration mistakenly exposed an internal business system to the internet, allowing unauthorized access to customer information and identity documents. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/digicert-data-breach-exposes-customer-information-identity-documents/

07. Scammers capitalize on GTA 6 hype to push malware and crypto cons

Scammers are offering supposed leaked builds, early copies and phone versions of Grand Theft Auto VI (GTA 6) weeks before the game’s November 19 launch, Netcraft warned in a new blog post. The company looked at GTA VI-themed domains that appeared between July 1 and October 27, 2026. Most of the lures fell into four groups, with sites borrowing the name of p…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/11/05/gta-6-scams-fake-leaks-early-access/

08. Norway's aid agency pwned and all users' data is stolen

Norad said it cannot be sure that the details of those in 'conflict areas and authoritarian states' are safe or not

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.theregister.com/cyber-crime/2026/11/05/norways-aid-agency-pwned-and-all-users-data-is-stolen/5307765

09. [+24h Old] Building incident playbooks for machine identity breaches

Pull up your SOC’s compromised account playbook and read through the first 15 minutes. Most SOCs begin their response by calling or messaging the user via Teams to ask whether the 2:00 am sign-in from an unfamiliar country was indeed them. Their subsequent actions depend upon what the user responds with. Try that with a service account, and you’ll be waitin…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.csoonline.com/article/4244632/building-incident-playbooks-for-machine-identity-breaches.html

10. [+24h Old] DreamHost confirms data breach exposed FTP logins and webmail sessions

DreamHost is warning of a data breach after attackers gained access to its File Manager platform for two months and stole customers' FTP/SFTP usernames and passwords. […]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/dreamhost-confirms-data-breach-exposed-ftp-logins-and-webmail-sessions/